

SEE ALSO: Newsletter of February 14, 2024

[doc. web n. 9978568]

Provision of December 7, 2023

Register of Provisions

n. 599 of December 7, 2023

THE GUARANTOR FOR THE PROTECTION OF PERSONAL DATA

IN the meeting held today, attended by

Prof. Pasquale Stanzone, president, Prof. Ginevra Cerrina Feroni, vice president, Dr. Agostino Ghiglia and Attorney Guido Scorza, members, and Cons. Fabio Mattei, secretary general;

HAVING REGARD TO Regulation (EU) 2016/679 of the European Parliament and of the Council, of April 27, 2016 (hereinafter "Regulation");

HAVING REGARD TO Legislative Decree No. 196 of June 30, 2003 (Code regarding the protection of personal data, hereinafter "Code") as amended by Legislative Decree No. 101 of August 10, 2018, containing "Provisions for the adaptation of national legislation to the provisions of Regulation (EU) 2016/679";

HAVING REGARD TO the inspection findings conducted by the undersigned Authority on July 26 and 27, 2022, at the registered office of Nirvam S.r.l. (in Bergamo);

HAVING EXAMINED the documentation on file;

HAVING REGARD TO the observations made by the secretary general pursuant to Article 15 of the Guarantor's Regulation No. 1/2000;

REPORTING Dr. Agostino Ghiglia;

PREMISE

1. The complaint and the investigative activity.

As part of a control activity initiated ex officio by the Authority, an on-site inspection was conducted on July 26 and 27, 2022, regarding Nirvam S.r.l.

The aforementioned Company, which has its registered office in Bergamo, manages an online dating platform aimed at allowing registered users to search for potential partners within the national territory.

Specifically, the Guarantor's control activity concerned the processing of personal data relating to users of the aforementioned platform, carried out by Nirvam S.r.l. in the context of the performance of the above-described dating activity.

In this regard, during the inspection, the data controller declared the following.

The Company manages "a dating site with a chat (www.nirvam.it)" through "paid subscriptions of the registered users" which can "last monthly, quarterly, semi-annually, or annually." It is also provided "the possibility of enjoying 3 days of free use of the site (...).

The "customer database has 4,788,451 registered accounts, of which 1,012,421 have validated emails, among which 9,147 have an active subscription. The unique users who have logged into the site are on average 23,331 (...). The domains nirvam.com, nirvam.it, nirvam.fr (French site), as well as other domains (e.g., nirvam.de) registered in the name of Mr. XX, pertain to the same service" (see minutes of July 26, 2022, p. 2).

Nirvam S.r.l. "has no employees nor a physical office and relies on two external collaborators for the validation of some content." For the provision of services accessible through the site "it uses proprietary servers, personally managed by Mr. XX – who is also the system administrator and software developer – located at the data center of Irideos S.p.A. (...), which provides connectivity and physical security services" (see minutes of July 26, 2022, p. 2).

Considering the circumstance that "a process of adaptation to the GDPR is still ongoing (...) the record of processing activities" referred to in Article 30 of the Regulation "was not prepared [as of the date of the aforementioned inspections]," "the data protection officer" referred to in Article 37 of the Regulation was not appointed, and no impact assessment on the protection of personal data was carried out pursuant to Article 35 of the Regulation (see minutes of July 26, 2022, pp. 3 and 4).

Regarding the security measures implemented to protect the personal data of the registered users, the Company first declared that it does not use intrusion detection and prevention systems, but "is studying the introduction of a firewall"; it also reported having arranged for "data backup, access via

VPN to the back-end of the site, access limitations (...), the use of BitLocker on the hard drives of laptops, and screen lock measures for devices in case of inactivity.” It also added that “a disaster recovery system is being implemented, with a snapshot option that allows recovery of the system's state to a certain date as well as the use of MFA systems for some systems” (see minutes of July 26, 2022, pp. 3-4).

From the on-site accesses, it also emerged that:

the data requested during registration on the site www.nirvam.it are: “interest in meeting; country, region, and city of residence; date of birth; email – which remains confidential; nickname; password chosen by the user.” Once registration is completed, “the user can optionally enter some descriptive data (height, weight, hair and eye color, profession, education level...), interests, the announcement that will appear in the personal profile, and the profile picture. The site then proposes some user profiles online, based on the city, region, and country indicated previously” (see minutes of July 27, 2022, pp. 1-2);

“the provided email address is verified through the sending of a confirmation email” (see minutes of July 27, 2022, pp. 1-2);

the access credentials to the backend of the site “are different services and for different devices”; “the file in which the passwords are stored is kept, in plain text, in the personal space [of the system administrator] on Onedrive” (see minutes of July 27, 2022, p. 2). Regarding the data retention timelines, it was stated that: Nirvam S.r.l. “does not have a document regarding data retention policies” (see minutes of July 27, 2022, p. 2); “registration data is retained until the user deletes it”; in any case, the Company “proceeds to massively delete accounts based on criteria defined from time to time (e.g., unvalidated email and absence of photo) to identify accounts that are no longer active”; “data relating to users who have taken the free trial without finalizing any subscription are, [instead], retained” potentially sine die (see minutes of July 27, 2022, p. 2); the number “of users for whom the date of the last access dates back to before January 1, 2012, is 1,262,678”; the number “of users for whom the date of the last access dates back to before January 1, 2012 and have unverified or currently invalid email is 1,145,691” (see minutes of July 27, 2022, p. 2); “when a user deletes their account from the site, the related photos are deleted. However, when a profile is deleted during a mass deletion carried out by the system administrator, the related photos are no longer accessible but are still retained in the file system, although they are not backed up” (see minutes of July 27, 2022, p. 3). In this regard, following access to the “Reserved Photos” table (i.e., photos “published within the user profile, accessible only at the user's discretion”), it emerged that “there are 135 IDs of reserved photos not associated with any user profile currently present in the DB.” From the checks regarding the table containing the “profile photos,” it was found that “there are 242 IDs of profile photos not associated with any user profile currently present in the DB.” Furthermore, the Company clarified that “upon the deletion of a user, data may remain in the linked tables, which are not deleted to avoid locking the database” (see minutes of July 27, 2022, p. 3).

2. Notification of violations and defensive memoranda.

With communication dated April 4, 2023, the Office, based on the documentation in the records and the elements acquired during the investigation, proceeded to notify Nirvam S.r.l. of the initiation of proceedings for the adoption of measures pursuant to Articles 58, paragraph 2, and 83 of the Regulation in relation to the violation of Article 5, paragraph 1, letters a), e) and f), and paragraph 2, of Article 9, of Article 13, of Article 32, as well as Articles 30, 35, and 37 of the Regulation; this in accordance with the provisions of Article 166, paragraph 5, of the Code. In this regard, the Company, with a note dated May 3, 2023, submitted its defensive writings, in which it represented the following: regarding the nature of personal data of the 135 IDs of “reserved photos” as well as the 242 IDs of “profile photos” whose presence in Nirvam's systems has been established (see note from the Authority pursuant to Article 166, paragraph 5 of the Code, sent on April 4, 2023, paragraph 3, p. 5), “the information in question concerns only ID numbers related to deleted fake accounts that cannot be associated in any way with user profiles and thus are not suitable for directly or indirectly identifying a natural person.” Nevertheless, these have been definitively deleted from the Company's systems following the contestation of the violations transmitted by the Authority pursuant to Article 166,

paragraph 5 of the Code (see note of May 3, 2023, p. 3). Regarding the 9,811 photos that, although they had been entered in the "dbo.dacancellare_fotoriservate" table, were still retained in the backend of the site (see note from the Authority pursuant to Article 166, paragraph 5 of the Code, sent on April 4, 2023, paragraph 3, p. 5), "the [aforementioned] 9,811 records [only concerned] ID numbers referring to users registered between 2005 and 2008, deleted in 2008 along with the related photos and identifying information, therefore (...) not qualifying as personal data at the time of the inspection. In any case, following internal checks, the table in question, which had been used to conduct a test on the operation of the first version of the deletion program to avoid data loss in case of bugs, has been definitively deleted from Nirvam's databases" (see note of May 3, 2023, p. 4). The Company also highlighted that it promptly activated, following the inspections carried out by the Authority, "with the support of a leading law firm to undertake a path aimed at remedying the vulnerabilities identified by the Authority" and that it "has currently implemented a documentation and procedural framework suitable for protecting the rights and freedoms of users of the website www.nirvam.it (the "Site") in compliance with the provisions of the Regulation" (see note of May 3, 2023, pp. 1-2). Specifically: it has integrated "the form used during registration on the Site, introducing a specific 'tick box' to allow users to provide, in a granular, specific, free, and informed manner, consent for the processing of special data in the context of using the dating services" offered by the Company (see note of May 3, 2023, p. 2); it has conformed the content of the information provided to the...

users to the provisions of Article 13 of the Regulation, reviewing the relevant document (see note of May 3, 2023, p. 3); has activated "a specific email address dedicated to requests related to the processing of personal data" (see note of May 3, 2023, p. 2); has identified, "in compliance with the principle of data retention limitation under Article 5, para. 1), lett. e), Regulation, the retention period in relation to each of the processing purposes, also with reference to the personal data of users who take the free trial without finalizing the purchase of a subscription," defining a specific data retention policy (see note of May 3, 2023, p. 3); has proceeded to delete the profiles of users whose last access was prior to January 1, 2013 (see note of May 3, 2023, p. 3); regarding security measures, "has implemented a new disaster recovery system, with snapshot option, for recovering the system state to a certain date," also providing "for the installation of the Watchguard M290 Firewall with Intrusion Prevention System" (see note of May 3, 2023, p. 4); has "(i) drafted a general procedure on the protection of personal data where the operational methods suitable for ensuring compliance with regulatory provisions, the terms and conditions for the acquisition and management of personal data, as well as the processes for managing data breaches and requests from data subjects are defined; (ii) defined the roles, responsibilities, operational methods, and rules to follow for the processing of personal data; (iii) planned the distribution of training material on data protection to raise awareness among those who process personal data on behalf of Nirvam. Lastly, (...) intends to plan the execution of a control and monitoring activity regarding the data protection compliance of the subjects appointed as data processors" (see note of May 3, 2023, p. 4); has finally prepared the record of processing activities, conducted the impact assessment pursuant to Article 35 of the Regulation, and initiated "a research and selection process aimed at identifying a professional figure with the independence requirements and specialized knowledge in data protection to be designated as the data protection officer pursuant to Article 37, Regulation" (see note of May 3, 2023, pp. 4-5). In this regard, at the specific request of the undersigned Authority (see note from the Guarantor dated June 28, 2023), the Company, with communication dated July 7, 2023, provided documentation certifying the above statements, consisting of: "Form used during the registration phase on the Site"; "Privacy notice provided to users of the website pursuant to Article 13 of the GDPR"; "Record of processing activities"; "General regulation on the protection of personal data"; "Impact assessment conducted pursuant to Article 35 of the GDPR."

3.1. The outcome of the investigation: the violation of the principles of lawfulness, fairness, and transparency.

First of all, it is noted that, unless the act constitutes a more serious offense, anyone who, in a proceeding before the Guarantor, falsely declares or certifies news or circumstances or produces false acts or documents is liable pursuant to Article 168 of the Code "Falsehood in declarations to the Guarantor and interruption of the execution of the tasks or the exercise of the powers of the

Guarantor."

Having duly stated this, following the examination of the elements acquired during the aforementioned checks, it has been established that the processing activities of the data of users registered on the site www.nirvam.it have been carried out by Nirvam S.r.l., as the data controller, in violation of the Regulation in the terms more broadly explained below.

The Company, through the services offered by the dating site www.nirvam.it, processes a series of personal information of the users registered on it (specifically: "interest in meeting; nationality, region, and city of residence; date of birth; email (...); nickname; password chosen by the user"), often contained in photos uploaded within the public profile or the reserved area of the registered accounts (see minutes of July 26, 2022, pp. 1-2 and minutes of July 27, 2022, pp. 1-2).

The aforementioned processing activities have involved approximately 1,012,421 users (see minutes of July 26, 2022, p. 2) and also special categories of data under Article 9 of the Regulation (specifically information suitable to reveal their sexual orientation and life).

In this regard, the Regulation provides that the processing of the aforementioned special categories of personal data can only be carried out in the presence of certain specific conditions identified by Article 9, para. 2, including the explicit consent of the data subject; conditions that are not found in the case at hand and whose absence is in contrast with the general prohibition of processing established therein (Article 9 of the Regulation).

In this regard, with specific reference to the case in question, the investigations conducted by the Authority have, in fact, highlighted the absence, at the time of registration on the site www.nirvam.it, of a procedure suitable for acquiring the explicit and informed consent of the data subjects; consent that is instead necessary pursuant to Article 9, para. 2, lett. a) of the Regulation to carry out the processing of personal data relating to the preferences and sexual orientations of the users themselves (see All. users, still represent personal data as they can be linked to the users' identities through other means.

3.3. The violation of the principle of data minimization.

Furthermore, it has been observed that the Company did not adhere to the principle of data minimization as set out in Article 5, paragraph 1, letter c) of the Regulation. This principle requires that personal data collected must be adequate, relevant, and limited to what is necessary in relation to the purposes for which they are processed.

In this regard, the Company retained a significant amount of data that was not necessary for the provision of its services, including data from users who had not completed their registration or had not subscribed to any service. The retention of such data, particularly when it pertains to users who had not engaged with the platform for an extended period, raises concerns regarding compliance with the principle of data minimization.

3.4. The violation of the principle of accuracy.

Moreover, it was found that the Company did not ensure the accuracy of the personal data it processed, as required by Article 5, paragraph 1, letter d) of the Regulation. The Company had not implemented adequate measures to keep personal data accurate and up to date, which is essential for the lawful processing of such data.

During the inspections, it was noted that the Company held outdated information regarding a substantial number of users, which could potentially lead to incorrect processing of their data. This lack of accuracy not only undermines the integrity of the data but also poses risks to the rights of the data subjects.

3.5. The violation of the principle of accountability.

Lastly, the Company failed to demonstrate compliance with the principle of accountability as outlined in Article 5, paragraph 2 of the Regulation. This principle requires that the data controller be responsible for and be able to demonstrate compliance with the principles relating to the processing of personal data.

The Company did not have adequate documentation or policies in place to show how it was complying with its obligations under the Regulation. This lack of accountability is concerning, as it indicates a

failure to take the necessary steps to ensure that personal data is processed in accordance with the law.

In conclusion, the findings from the inspections indicate multiple violations of the principles established by the Regulation, which raises significant concerns regarding the Company's practices in relation to the processing of personal data. The Company must take immediate action to address these issues and ensure compliance with the applicable legal framework.

****Users****, by their very nature, contain elements characteristic of the physical traits of the individuals depicted therein, capable of allowing for their identification nonetheless. The elements collectively noted above have highlighted, in light of the findings above, the violation of Article 5, paragraph 1, letter e) of the Regulation.

Conversely, regarding the alleged violation of the principle of data retention limitation concerning the 135 IDs of "private photos" as well as the 242 IDs of "profile photos" - none of which are associated with a user account (see violation notification of April 4, 2023, p. 5) - consideration is given to what has been represented by the Company in its defense submissions (see paragraph 2 of this provision), regarding the circumstance that the aforementioned IDs consisted of mere numerical strings "related to deleted fake accounts not associable in any way to user profiles and therefore unsuitable to directly or indirectly identify a natural person."

Therefore, with respect to this specific case, there are no grounds to adopt measures concerning the related violation (Article 5, paragraph 1, letter e) of the Regulation) contained in the notification from the undersigned Authority dated April 4, 2023. Thus, the request made by Nirvam S.r.l. for the dismissal of the contestation concerning this specific violation is accepted, but only with respect to this limited profile.

Lastly, with specific reference to the data retention timelines reported by the Company within the "Record of Processing" submitted to the undersigned Authority during the proceedings (see note of July 7, 2023, Annex C), it is observed that they do not appear, even today, to comply with the aforementioned principle of data retention limitation.

Nirvam S.r.l., in fact, has established unique timelines for almost all the processing identified therein (mostly consisting of 10 years from the deletion of the user profile); timelines that, while appearing justified with respect to certain types of information (such as, hypothetically, common data necessary for billing services), are instead absolutely disproportionate concerning processing involving different categories of personal data and distinct purposes (see, for example, among many, the category of "user profile data," data which, as they may also include particularly sensitive information such as that related to the sexual orientation or sexual life of the individuals concerned, should have retention timelines strictly correlated to the purposes of the related processing).

****3.3. Violation of the principle of integrity and confidentiality.****

Regarding the security measures adopted, it has emerged that these consisted, at the time of the inspection assessment:

- in automatic checks on the IPs from which users access the site;
- in the execution of "manual queries" on the database and automatic checks to identify the execution of malicious code;
- in the verification of messages exchanged between users to encode potentially dangerous characters;
- in access to the servers, exclusively by the system administrator;
- in the use of a single proprietary software developed ad hoc;
- in the disabling of the admin account on all machines;
- in the encryption of the disks of the computers used to access the back-end servers with Bitlocker.

However, considering the risks presented by the specific processing carried out, these measures have proven inadequate to ensure the integrity and confidentiality of the personal information processed therein.

It is indeed evident, taking into account the peculiar type of service provided by the website www.nirvam.it, that the personal data of the users subscribed to it constitute - as already noted above - information of an extremely sensitive nature, as they are capable of revealing the preferences and sexual orientation of the individuals concerned.

Due to such characteristics, the related processing requires specific security measures, proportionate to the significant risks associated with it. This is especially true concerning the photographic materials uploaded by the users themselves, which may contain explicit content deserving of specific protection.

In light of the necessity for particularly effective measures to protect the rights and freedoms of the individuals concerned, the methods of developing the site and providing the related services, implemented by Nirvam S.r.l. since its establishment, have proven to be approximate and inadequate.

The creation, management, and maintenance of the service have indeed appeared to be based on a technically inadequately organized approach, and their verification over time has been conducted in the absence of suitable planning, control, and documentation.

This circumstance has resulted in the management and maintenance of the application and the infrastructure as a whole being handled without specific programming and not following consolidated and certified methodologies.

This has been clearly evidenced by the absence of consolidated processes for evolutionary maintenance, which has caused, among other things, the partial deletion of the profiles of users who have made...

request, as well as from the failure to adopt essential security policies for the management of a service aimed at processing the aforementioned special categories of personal data.

In this regard, it is necessary to highlight the violation by Nirvam S.r.l. of Articles 5, paragraph 1, letter f) and 32 of the Regulation, as the infrastructure related to processing was found to be lacking adequate measures for the retention of users' personal data, deletion policies, structured systems for backup and disaster recovery, and physical, IT, and infrastructural security measures.

It should be noted that, although the Company, during the proceedings, declared that it had implemented "a new disaster recovery system, with snapshot option," and also proceeded "with the installation of the Watchguard M290 Firewall with Intrusion Prevention System" (see note of May 3, 2023, p. 4; see also paragraph 2 of this decision), the measures adopted and resulting from the documentation submitted in the note of July 7, 2023, do not yet appear sufficient to bring the processing into compliance with the provisions of Article 32 of the Regulation.

Based on the analysis of the documentation provided by the Company (see note of July 7, Attachments C and D), the measures adopted therein cannot be considered adequate to the risks presented by the processing in question. In fact, they appear to be mostly a mere repetitive restatement of intentions rather than real measures accompanied by a plan for implementation and execution. They have been applied indiscriminately to treatments that are very different from each other in terms of risk to the rights and freedoms of individuals; this is true both for the type of data processed and for the categories of data subjects involved (consider, for example, the differences in risk between the management of data of consultants for the purposes of assisting the Company and the processing related to the creation of a list of user profiles of interest within the dating platform).

Moreover, it was not possible to find in the documentation presented by the data controller specific technical measures to protect particularly sensitive data, as they are suitable for detecting users' sexual orientation and life (such as those specifically aimed at reducing any unauthorized or abusive access to the data contained in the dating platform, as well as those aimed at preventing possible forms of dissemination of the information present therein); this is true both for the systems dedicated to managing subscriber data and for those aimed at users of the website www.nirvam.it for the time necessary to carry out the free trial of the aforementioned services.

Similarly, no indication was provided by the Company regarding the identity and access management

system for authorized subjects to access the data for technical assistance activities on the systems and customer care, nor regarding the definition of their respective roles and profiles.

3.4. Further Violations.

Lastly, in relation, more generally, to compliance with the obligations imposed by the Regulation on the data controller, it is also noted that Nirvam S.r.l., although required to do so under Article 30, paragraph 1 of the Regulation, has not drafted the record of processing activities (see minutes of July 26, 2022, p. 3).

Furthermore, it has not appointed a Data Protection Officer (DPO), nor has it prepared a data protection impact assessment (see minutes of July 26, 2022, pp. 3 and 4); this despite the fact that Nirvam S.r.l., due to the significant risks associated with the processing activities related to the use of the dating platform it manages, as well as in relation to the large number of personal data referred to in Article 9 of the Regulation processed internally, is instead obliged to adopt both of the aforementioned obligations.

In this regard, in fact, taking into account what emerged from the inspection findings regarding the scale of the processing activities carried out by the data controller (4,788,451 registered accounts on the dating site, of which 1,012,421 correspond to validated users at the time of the inspection, see minutes of July 26, 2022, p. 2), it is possible to find in this case the requirement set out in Article 37, paragraph 1, letter c) of the Regulation, consisting of "large-scale processing of special categories of personal data." The failure to comply with these provisions has resulted in violations of Articles 30, 35, and 37 of the Regulation.

With specific reference to the impact assessment, it is also noted that the document sent to the Authority after the phase of contesting the violations (see note of July 7, Attachment E) does not appear to meet the requirements set out in Article 35 of the Regulation, as "the measures [therein] provided to address the risks" of processing do not seem adequate to mitigate them (Article 35, paragraph 2, letter d) of the Regulation); this is particularly considering that the aforementioned measures, described in a rather generic and summary manner, are applied indiscriminately to all identified threats, regardless of the level of severity and probability of each of them.

From the overall picture of all the individually presented violations, it emerges, more generally, that the technical and organizational measures collectively adopted by the data controller to bring the processing into compliance with the Regulation did not appear, at the time of the inspection (nor do they appear to this day), adequate to the nature, context, purposes, and Regulation, tenendo conto dei rischi specifici per i diritti e le libertà degli interessati, nonché delle misure di mitigazione appropriate;

e) designare un Responsabile della protezione dei dati, qualora non già fatto, in conformità con l'art. 37 del Regolamento, e garantire che il Responsabile della protezione dei dati sia adeguatamente coinvolto in tutte le questioni relative alla protezione dei dati;

f) implementare un programma di formazione per il personale, volto a garantire che tutti i dipendenti siano consapevoli delle loro responsabilità in materia di protezione dei dati e delle procedure interne da seguire;

g) stabilire procedure per la gestione delle richieste di esercizio dei diritti degli interessati e dei reclami, assicurando che tali procedure siano facilmente accessibili e comunicate agli utenti;

h) predisporre audit interni ed esterni periodici per verificare la conformità alle normative sulla protezione dei dati e alle politiche interne adottate.

Si richiede che tali misure correttive siano attuate entro un termine di 90 giorni dalla notifica del presente provvedimento. Al termine di tale periodo, la Società dovrà presentare un rapporto dettagliato all'Autorità, attestante l'implementazione delle misure sopra indicate e l'adeguamento alle disposizioni del Regolamento.

In caso di inadempimento, l'Autorità si riserva il diritto di adottare ulteriori misure, inclusa l'imposizione di sanzioni amministrative, ai sensi dell'art. 83 del Regolamento.

Il presente provvedimento è notificato a Nirvam S.r.l. e sarà pubblicato sul sito web dell'Autorità, in conformità con le disposizioni di trasparenza previste dal Regolamento.

Data e luogo di emissione.

Firma dell'Autorità.

Regulation, detailing the measures implemented by the data controller to address the risks associated with the processing activities carried out by the platform www.nirvam.it.

The aforementioned measures, in light of the high risks associated with the processing activities carried out by the same, must be implemented promptly and urgently as they are necessary to ensure an initial and immediate protection of the sensitive information processed through the site www.nirvam.it. For this purpose, consideration is also given to the possibility of implementing them in a short timeframe, as well as to the study and analysis activities already initiated by Nirvam S.r.l. during the proceedings (see what has been stated by the data controller regarding the assignment given to a specialized law firm; cf. note of May 3, 2023, pp. 1-2).

Furthermore, with reference more generally to the entire organizational framework implemented by the data controller for the provision of online dating services, the following additional measures are prescribed:

- e) adopt an Identity and Access Management system to identify profiles and roles of individuals operating on the site and on the systems used by the company;
- f) adopt specific measures to protect the special data processed by the Company, such as, for example, encryption or pseudonymization measures for such types of data;
- g) store the special data processed by Nirvam S.r.l. in a partition of the back-end of the site accessible only to a limited number of individuals;
- h) provide a proper tracking system for operations performed on the data and on the systems used by the Company, which allows for the recording, for each data access operation, including consultation and production of reports even in aggregated form, at least the following information:
 - user that performed the access operation;
 - date and time of execution;
 - reference of the user subject to the data access operation;
 - purpose of the access, type of operation performed, and data examined;
- i) equip log files with timestamps and integrity checks to guarantee their immutability and authenticity, also by using digital signature techniques and certified logging systems. Access to log files must be allowed only to individuals with pre-identified authorization profiles, and such access must also be subject to tracking;
- j) adopt a formalized procedure for the deletion of user profiles, even when present on the site for a free trial only, which includes verification of the deletion of all related data, including those present in referenced tables or in unstructured archives stored on the file system. In particular, adopt measures aimed at ensuring that the user profile, where the user has requested the deletion of their account, is no longer visible to other users, resulting in its removal from the list of profiles of interest to third parties;
- k) adopt intrusion detection and prevention systems to identify harmful activities on the systems and the execution of malicious code, as well as any attempts of unauthorized access, adopting the necessary countermeasures.

5. Adoption of the injunction order for the application of the administrative pecuniary sanction and accessory sanctions (Articles 58, paragraph 2, letter i), and 83 of the Regulation; Article 166, paragraph 7, of the Code).

The Guarantor, pursuant to Article 58, paragraph 2, letter i) of the Regulation and Article 166 of the Code, has the power to impose an administrative pecuniary sanction provided for by Article 83 of the Regulation, through the adoption of an injunction order (Article 18, Law of November 24, 1981, No.

689), in relation to the processing of personal data carried out by Nirvam S.r.l., which has been found to be unlawful, as stated above.

It is deemed necessary to apply paragraph 3 of Article 83 of the Regulation where it states that “if, in relation to the same processing or to related processing, a data controller [...] violates, with intent or negligence, various provisions of this regulation, the total amount of the administrative pecuniary sanction does not exceed the amount specified for the most serious violation,” the total amount of the sanction is calculated so as not to exceed the maximum penalty provided for by the same Article 83, paragraph 5.

With reference to the elements listed in Article 83, paragraph 2 of the Regulation for the application of the administrative pecuniary sanction and its quantification, considering that the sanction must be “effective, proportionate, and dissuasive in each individual case” (Article 83, paragraph 1 of the Regulation), it is represented that, in the case at hand, the following circumstances have been taken into account:

- the significant severity of the violations (Article 83, paragraph 2, letter a) of the Regulation), in relation to their nature — as they concern non-compliance with the general principles of processing — as well as the high number of affected individuals (approximately one million). These elements are further aggravated by the considerable duration of the unlawful conduct:

the latter, in fact, has been perpetrated continuously for as long as 16 years and still persists in part today, despite the measures adopted in the meantime by the data controller to align its processing activities with the Regulation (see above, para. 4)

- the significant degree of responsibility of the data controller (art. 83, para. 2, lett. b) and d) of the Regulation) specifically regarding the failure to adopt technical and organizational measures aimed at ensuring compliance of the processing with the Regulation. In this regard, particular attention is given to the fact that the inadequacy of the accountability tools adopted by the data controller in this case generally concerned the management of the online dating platform, highlighting systemic deficiencies in the entire process of managing the personal data processing activities of users;
- the extremely sensitive nature of the information subject to violation (art. 83, para. 2, lett. g) of the Regulation) as it is capable of revealing the life and sexual orientation of the data subjects;
- the adoption by the data controller of some measures to mitigate the consequences of the violation (art. 83, para. 2, lett. c) of the Regulation). In this regard, it should be positively noted that Nirvam S.r.l. promptly adopted the measures described in para. 2 of this provision (see also above, para. 4);
- the fact that the Company actively cooperated with the Authority during the proceedings (art. 83, para. 2, lett. f) of the Regulation);
- the absence of previous violations committed by the data controller or measures referred to in art. 58 of the Regulation (art. 83, para. 2, lett. e) of the Regulation).

It is also considered that the economic conditions of the offender, determined based on the Company's turnover as per the financial statements for the year 2022 (the latest available), are relevant in this case, due to the aforementioned principles of effectiveness, proportionality, and deterrence to which the Authority must adhere in determining the amount of the sanction (art. 83, para. 1, of the Regulation).

Finally, account is taken of the costs that the Company is required to incur to comply with the prescriptions set out in paragraph 4 of the aforementioned decision.

In light of the above elements and the evaluations made, it is deemed appropriate, in this case, to impose on Nirvam S.r.l. an administrative sanction of a payment of an amount equal to €200,000.00 (two hundred thousand/00).

In this context, it is also considered that pursuant to art. 166, paragraph 7, of the Code and art. 16, paragraph 1, of the Regulation of the Guarantor no. 1/2019, the publication of this provision on the Guarantor's website should proceed.

All this in consideration of the particular nature of the personal data processed by the Company, relating to the life and sexual habits of the data subjects involved, as well as the type of violations established that have affected the general principles of processing, particularly the principles of lawfulness, fairness, transparency, data retention limitation, integrity, confidentiality, and

accountability.

It is also noted that the various violations established in this case have highlighted a generalized and systematic non-compliance by the aforementioned data controller with the regulations on personal data protection.

Finally, it is believed that the conditions set out in art. 17 of the Regulation of the Guarantor no. 1/2019 are met.

ALL OF THE ABOVE CONSIDERED, THE GUARANTOR

a) pursuant to arts. 57, para. 1, lett. a) and 83 of the Regulation and art. 144, para. 2 of the Code, finds the unlawfulness of the processing carried out by Nirvam S.r.l., based in Bergamo, VAT no.

03350600163, as stated in the reasoning, for the violation of art. 5, para. 1, lett. a), e) and f) and para. 2, of art. 9, of art. 13, of art. 24, of art. 32, as well as of arts. 30, 35, and 37 of the Regulation;

b) pursuant to art. 58, para. 2, lett. d) of the Regulation, orders the aforementioned Company to comply, within 45 days from the date of notification of this provision, with the prescriptions formulated in para. 4, letters a) to d) of this provision, simultaneously requesting it to communicate what initiatives it intends to undertake in order to implement the provisions and to provide, within the aforementioned term, adequately documented feedback pursuant to art. 157 of the Code; any failure to respond may result in the application of the administrative monetary sanction provided for by art. 83, para. 5, lett. e) of the Regulation;

c) pursuant to art. 58, para. 2, lett. d) of the Regulation, orders the aforementioned Company to comply, within nine months from the date of notification of this provision, with the prescriptions formulated in para. 4, letters e) to k) of this provision, simultaneously requesting it to communicate what initiatives it intends to undertake in order to implement the provisions and to provide, within the aforementioned term, adequately documented feedback pursuant to art. 157 of the Code; any failure to respond may result in the application of the administrative monetary sanction provided for by art. 83, para. 5, lett. e) of the Regulation;

d) believes that the conditions set out in art. 17 of Regulation no. 1/2019 concerning internal procedures with external relevance, aimed at carrying out the tasks and exercising the powers entrusted to the Guarantor, are met.

ORDER

pursuant to Article 58, paragraph 2, letter i) of the Regulation, to Nirvam S.r.l., to pay the sum of €200,000.00 (two hundred thousand/00) as an administrative monetary sanction for the violations indicated in this provision.

ORDERS

therefore Nirvam S.r.l. to pay the aforementioned sum of €200,000.00 (two hundred thousand/00), according to the methods indicated in the attachment, within thirty days from the notification of this provision, under penalty of the adoption of the consequent enforcement acts in accordance with Article 27 of Law No. 689/1981. It is noted that pursuant to Article 166, paragraph 8 of the Code, the offender retains the option to settle the dispute by paying - always according to the methods indicated in the attachment - an amount equal to half of the imposed sanction within the term provided by Article 10, paragraph 3, of Legislative Decree No. 150 of September 1, 2011, for the submission of the appeal as indicated below.

PROVIDES

for the publication of this provision on the website of the Authority pursuant to Article 166, paragraph 7, of the Code and Article 16, paragraph 1, of the Regulation of the Authority No. 1/20129.

Pursuant to Article 78 of the Regulation, as well as Articles 152 of the Code and 10 of Legislative Decree No. 150/2011, an appeal against this provision may be brought before the ordinary judicial authority, with an application filed at the ordinary court of the place identified in the same Article 10, within the term of thirty days from the date of communication of the provision itself, or sixty days if the appellant resides abroad.

Rome, December 7, 2023

THE PRESIDENT

Stanzione

THE REPORTER

Ghiglia

THE SECRETARY GENERAL

Mattei